

MITRE ATT&CK RESEARCH INTERNSHIP

Group Leader Selection Program

Threat Intelligence Research Report

Intern ID	2101
Assigned Campaign	Campaign No. 01 – Frankenstein (C0001)
Software Range	S0010 – S0020 (11 Entries)
Submission Date	May 15, 2026
Research Platform	https://attack.mitre.org/
Report Classification	CONFIDENTIAL – INTERN EVALUATION

PREPARED BY: INTERN 2101

MITRE ATT&CK Research Internship – Cohort 2026

PART I

CAMPAIGN RESEARCH: FRANKENSTEIN (C0001)

1. Campaign Overview

The Frankenstein campaign (MITRE ATT&CK ID: C0001) was a series of highly targeted cyberattacks identified by Cisco Talos researchers in 2019. The campaign derived its name from the adversaries' distinctive methodology of assembling their malicious toolkit from several unrelated, freely available open-source components — much like the fictional monster stitched together from disparate parts.

What made Frankenstein operationally notable was not sophisticated zero-day exploitation but rather resourceful assembly of existing tools. The actors demonstrated high operational security discipline, anti-analysis awareness, and encrypted communications — hallmarks of a professionally organized threat actor group.

MITRE ID	C0001
Campaign Name	Frankenstein
First Seen	January 2019
Last Seen	April 2019
Duration	Approximately 4 months
Identified By	Cisco Talos (Danny Adamitis, David Maynor, Kendall McKay)
Published	June 4, 2019
MITRE Version	1.1 (Last Modified: April 16, 2025)
Threat Actor	Unidentified (Unknown APT)
Classification	Targeted Espionage / Credential Harvesting

2. Threat Actor / Group Association

The threat actors behind the Frankenstein campaign have not been attributed to a known, named APT group. Cisco Talos assessed them as moderately sophisticated but highly resourceful. Key indicators pointing to an organized, state-linked or professional crime group include:

- Use of hyper-targeted spearphishing documents with context-specific lures (e.g., a document displaying Jordan's national flag, references to Middle Eastern entities)
- Deliberate operational security: VM-detection, analysis tool detection, predefined GET request fields to restrict C2 responses
- Encryption of C2 traffic using AES-CBC
- Use of exclusively open-source tooling to frustrate attribution — a technique consistent with state-sponsored actors seeking plausible deniability
- Appearance of Kaspersky-branded document lures, potentially indicating targeting of users who trust security vendor communications

The campaign's targeting of Middle Eastern entities and the sophistication of its anti-detection measures suggest the actors may have regional intelligence interests, though attribution remains inconclusive.

3. Campaign Timeline

January 2019	Campaign begins; first malicious documents identified in malware repositories
---------------------	---

January–March 2019	Wave 1: CVE-2017-11882 exploit documents delivered via spearphishing; scheduled task persistence established
February–April 2019	Wave 2: Macro-enabled documents with VBA scripts incorporating VM/analysis-tool detection
April 2019	Campaign concludes; last activity observed
June 4, 2019	Cisco Talos publicly discloses the Frankenstein campaign with full technical analysis
September 7, 2022	MITRE ATT&CK formally creates campaign entry C0001
April 16, 2025	MITRE ATT&CK entry last modified (v1.1)

4. Objectives of Attack

Based on Cisco Talos research and MITRE ATT&CK mapping, the primary objectives of the Frankenstein campaign were:

- **Credential Harvesting:** The Empire agent collected usernames, domain names, machine names, public IP addresses, administrative privilege levels, running processes, OS version, and SHA256 HMAC values
- **Initial Foothold Establishment:** Delivery of malware via weaponized documents to gain persistent access on victim machines
- **System Reconnaissance:** Gathering of host-based intelligence to enable follow-on operations
- **Persistent Remote Access:** Establishing scheduled tasks and using PowerShell Empire for long-term C2 channel maintenance
- **Covert Intelligence Collection:** The hyper-targeted nature and anti-detection features suggest the goal was intelligence gathering rather than financial crime or ransomware deployment

5. Targeted Sectors / Countries

The Frankenstein campaign demonstrated selective, hyper-targeted characteristics with a low volume of documents found across malware repositories. Based on document lures and contextual evidence:

- **Geographic Targeting:** Middle Eastern entities, with specific use of a document displaying the national flag of Jordan; additional documents likely targeting the broader Middle East region
- **Sector Targeting:** Government and diplomatic entities (inferred from document themes and targeting precision)
- **Lure Themes:** A document named 'MinutesofMeeting-2May19.docx' consistent with government/organizational meeting themes; documents spoofing Kaspersky (targeting security-aware users)

The specific combination of Jordan-flag lure documents and Middle Eastern organizational themes suggests government or diplomatic sector targeting in or around the Levant/Middle East region.

6. Attack Flow

Wave 1 – CVE-2017-11882 Exploitation Path

- **Stage 1 – Initial Access:** Victim receives spearphishing email with weaponized Word document (e.g., 'MinutesofMeeting-2May19.docx'). Document displays national flag of Jordan as a lure. [T1566.001 – Spearphishing Attachment]
- **Stage 2 – Template Fetch:** On open, the document fetches a remote template from actor-controlled domain: hxxp://droobox[.]online:80/luncher.doc. [T1221 – Template Injection]
- **Stage 3 – Exploitation:** Downloaded luncher.doc exploits CVE-2017-11882 (Microsoft Office Equation Editor RCE) to execute code on the victim machine. [T1203 – Exploitation for Client Execution]

- Stage 4 – Persistence: Post-exploit, a command script creates a scheduled task named 'WinUpdate' (/Create /F /SC DAILY /ST 09:00). [T1053.005 – Scheduled Task]
- Stage 5 – Stager Execution: Scheduled task runs base64-encoded PowerShell commands acting as a stager (derived from FruityC2 GitHub project). [T1059.001 – PowerShell]
- Stage 6 – C2: PowerShell Empire agent deployed; system info collected and sent to C2 via AES-CBC encrypted channel. [T1071.001 – Web Protocols]

Wave 2 – Macro/VBA Execution Path

- Stage 1 – Initial Access: Victim receives document prompting macro enablement. [T1566.001 – Spearphishing Attachment]
- Stage 2 – VBA Execution: Macro executes a Visual Basic Application (VBA) script. [T1059.005 – Visual Basic]
- Stage 3 – Anti-Analysis Checks: VBA queries WMI to detect running tools: VMWare, VirtualBox, Process Explorer, Process Hacker, ProcMon, Fiddler, Wireshark. Also checks core count (exits if < 2 cores). [T1497 – Virtualization/Sandbox Evasion, T1082 – System Info Discovery]
- Stage 4 – MSBuild Execution: If checks pass, MSBuild executes an actor-created XML file (%LOCALAPPDATA%\Intel\instal.xml) to bypass application whitelisting. [T1127.001 – MSBuild]
- Stage 5 – Empire Agent: PowerShell Empire agent gathers system intelligence and establishes encrypted C2. [T1071.001, T1027 – Obfuscated Files]

7. MITRE ATT&CK Techniques Used

The following techniques have been mapped to the Frankenstein campaign based on MITRE ATT&CK C0001 and Cisco Talos analysis:

Technique ID	Technique Name	Usage in Frankenstein
T1566.001	Spearphishing Attachment	Primary initial access vector; weaponized Word documents sent to victims
T1203	Exploitation for Client Execution	CVE-2017-11882 (MS Office Equation Editor) triggered via remote template
T1221	Template Injection	Remote template fetched from droobox[.]online:80/luncher.doc
T1053.005	Scheduled Task/Job: Scheduled Task	Persistence via 'WinUpdate' daily scheduled task
T1059.001	Command and Scripting: PowerShell	Base64-encoded PowerShell stager and Empire agent execution
T1059.005	Command and Scripting: Visual Basic	VBA macro executing anti-analysis checks and payload
T1127.001	Trusted Developer Utilities: MSBuild	MSBuild used to execute instal.xml, bypassing app whitelisting
T1497	Virtualization/Sandbox Evasion	VM detection via WMI queries (VMWare, VirtualBox, VxStream)
T1057	Process Discovery	Checking running processes for analysis tools (Process Explorer, Fiddler, etc.)
T1082	System Information Discovery	Collecting OS version, machine name, core count via WMI
T1033	System Owner/User Discovery	Username, domain, admin privileges collected by Empire agent

T1016	System Network Configuration Discovery	Public IP address collected by Empire agent
T1071.001	Application Layer Protocol: Web Protocols	C2 communication using HTTP/HTTPS
T1573	Encrypted Channel	AES-CBC encryption used to protect data in C2 transit
T1027	Obfuscated Files or Information	Base64-encoded PowerShell commands used for obfuscation
T1105	Ingress Tool Transfer	FruityC2 stager used to fetch Empire agent components

8. Real-World Incidents

The Frankenstein campaign, while limited in volume, presents several operationally significant real-world characteristics:

- **Document Lures:** Investigators discovered at least two distinct weaponized documents — one titled 'MinutesofMeeting-2May19.docx' displaying Jordan's national flag (indicating Middle Eastern targeting), and others spoofing Kaspersky security communications to deceive security-aware users
- **Exploitation of Legacy Vulnerabilities:** The campaign relied on CVE-2017-11882, a vulnerability disclosed in 2017 and patched via MS17-006. This indicates that the targeted organizations had failed to apply patches approximately two years after release — a real-world operational gap widely observed in government and industrial environments
- **Open-Source Tool Chain:** By exclusively using publicly available components (FruityC2, MSBuild techniques, Empire, VM-detection articles), the actors established plausible deniability, making forensic attribution to a specific group extremely difficult — a deliberate real-world tradecraft choice
- **Infrastructure:** The C2 domain droobox[.]online was registered and controlled by the actors, demonstrating independent infrastructure management
- **Low-Volume Targeting:** The discovery of only a small number of documents across malware repositories confirms hyper-targeted operations — a characteristic of intelligence-driven campaigns rather than opportunistic mass-exploitation

9. Detection Opportunities

Network-Based Detections

- Monitor for HTTP GET requests with unusual user-agent strings and session cookies matching non-standard formats — Frankenstein C2 only responded to requests with predefined fields
- Detect DNS resolution and HTTP connections to newly registered or low-reputation domains from Office processes (Word, Excel fetching remote templates)
- Alert on AES-CBC encrypted communications from non-standard processes or unexpected destinations

Endpoint-Based Detections

- Alert on scheduled task creation by Office application processes or with names like 'WinUpdate' via schtasks.exe or Task Scheduler APIs [T1053.005]
- Detect MSBuild.exe (C:\Windows\Microsoft.NET\Framework) executing XML files from user-writable directories like %LOCALAPPDATA% — a strong indicator of T1127.001 abuse
- Monitor PowerShell execution with base64-encoded arguments (-EncodedCommand flag) spawned from Office processes
- Alert on WMI queries from VBA/macro processes enumerating running processes or checking virtualization indicators
- Detect outbound network connections from MSBuild.exe or PowerShell.exe to external IPs

Behavioral Analytics

- Chain detection: Office document open → remote template fetch → scheduled task creation → PowerShell execution — this sequence is a high-fidelity Frankenstein indicator
- Detect Empire agent checkins: periodic HTTPS beacon traffic with characteristic user-agent strings or URI patterns

10. Defensive Recommendations

- PATCH MANAGEMENT [Critical]: Immediately apply MS17-006 for CVE-2017-11882. Implement a mature vulnerability management program to prevent exploitation of 2+ year-old known vulnerabilities
- DISABLE MACROS [High]: Configure Group Policy to block VBA macros in Office documents from the internet (HKEY_CURRENT_USER\Software\Microsoft\Office\<version>\<app>\Security\VBAWarnings = 4)
- APPLICATION WHITELISTING [High]: Deploy AppLocker or Windows Defender Application Control (WDAC) policies to restrict MSBuild.exe execution to authorized build environments only
- POWERSHELL CONSTRAINED LANGUAGE MODE [High]: Enable PowerShell Constrained Language Mode and configure AMSI to scan PowerShell scripts, reducing Empire agent effectiveness
- EMAIL SECURITY [High]: Deploy advanced email gateway solutions to inspect and sandbox Office document attachments; implement DMARC/DKIM/SPF to reduce spearphishing
- NETWORK SEGMENTATION [Medium]: Prevent workstations from making direct outbound HTTP/HTTPS connections; route through proxies with SSL inspection
- EDR DEPLOYMENT [High]: Deploy an EDR solution capable of detecting process chains (Word → PowerShell → MSBuild), anomalous scheduled task creation, and Empire beaconing
- USER AWARENESS [Medium]: Train users to be skeptical of documents requesting macro enablement or displaying unusual content, even when appearing to come from trusted sources (e.g., security vendors)
- THREAT HUNTING [Ongoing]: Hunt for base64-encoded PowerShell commands in process logs, MSBuild execution from non-standard directories, and scheduled tasks with names mimicking system tasks